

Eng 4.6. Weaponizing Vulnerabilities

Task 1 - Introduction

Weaponizing a vulnerability refers to the process of taking a known vulnerability in a software or system and creating an exploit for it, which can then be used to gain unauthorized access or perform other malicious actions.

The goal of weaponizing vulnerabilities is to take advantage of a single vulnerability or set of vulnerabilities that can be chained to get elevated access to a system. Despite the safeguards already in place, every system or equipment within a firm may have vulnerabilities. This encompasses not only all physical hardware, such as desktop computers, laptops, and servers, but also all virtual platforms, cloud-based resources, mobile devices, and more. The [National Vulnerability Database \(NVD\)](#)[\(opens in new tab\)](#) claims that the rate at which vulnerabilities have been discovered has increased recently.

An exploit may be utilized in conjunction with additional exploits or vulnerabilities for the attacker to take control of a system they are targeting. Even though a vulnerability's impact isn't as significant as another that is more difficult to access, it might still be quite simple to attack.

Task 2 - What is an Exploit?

An exploit can take various forms, such as an executable file designed for a specific endpoint, which can be delivered through a text message, an email attachment, or even a file that is hidden within digital files. When the exploit is executed, an attacker can perform various actions on the targeted system, such as controlling it remotely or locally, disrupting its functionality, stealing data, or any other activities that the system's resources allow.

An exploit can be either local or remote. An attacker who already has access to a specific computing resource can execute code locally to escalate their privileges. They may also install additional malicious code or gain remote control of the resource. An attacker who exploits a vulnerability remotely over a network or

communication channel to gain control of a system uses a specific type of exploit, known as a remote exploit. An exploit is a technical tool that may be used against any user in a standalone or connected cyber environment. In a standalone environment, an exploit may be delivered via removable media.

Exploits can be developed and financed by various actors, including nation-states seeking to engage in cyber espionage or cyber warfare, organized criminal groups looking to profit from their activities, and hackers on the dark web selling their services to the highest bidder. Additionally, some specialized actors look for weaknesses and develop exploits for them. It's critical to realize that an exploit is not a goal in and of itself. It is a method for carrying out much more significant tasks. Exploit creation is a complicated process requiring high information security expertise. As a result, it involves highly experienced individuals and continuous updates that can fetch a high price on niche or illegal markets (mainly on the dark web)

Answer the questions below

What is the term for an exploit that is used to gain control of a system remotely?

remote exploit

Task 3 - Vulnerability Lifecycle

The Department of Defense (DoD) has implemented a Vulnerability Disclosure Program (VDP)(opens in new tab) that uses the widely recognized Lifecycle of a Vulnerability Framework(opens in new tab) to better understand how vulnerabilities can be mitigated earlier. A VDP typically involves the triage, validation, and mitigation facilitation of vulnerability reports submitted by researchers. The five stages of the Lifecycle of a Vulnerability Framework are **Discovery, Coordination, Mitigation, Management, and Lessons Learned**; however, the path a vulnerability follows from identification to patching can vary. The following flow displays the different stages of the lifecycle of a vulnerability in a more-or-less linear manner.



- **Product Launched:** A vendor in the public market launches an information technology product (hardware or software).
- **Vulnerability Discovery (Public or Private):** Researchers working independently or sponsored by private/public organizations for various interests discover vulnerabilities in the product. A 0-day vulnerability is one that has yet to be made public after being found. In any other case, when a vulnerability is found, it is made available to the general public via the internet or other special sources. Before the vulnerability is publicly disclosed online, the manufacturer typically has already developed a patch or update for the product at this stage.
- **Development of a Proof of Concept (PoC) or Exploit:** A PoC proving the exploitability of the newly discovered vulnerability is prepared in-house by the vendor or received from bug bounty hunters/independent researchers. It is crucial at this stage to keep the vulnerability disclosure discrete as the PoC is typically the first stage in developing an exploit, and bad actors can use it in the wild.
- **Patch Development or Update:** The product manufacturer creates a patch or update to prevent the known vulnerability from being exploited by adversaries.
- **Patch Release:** The product manufacturer releases the patch for the vulnerability so the customers can apply it to the product in their environment.
- **Patch Install:** The customer or end-users update or patch their systems, so the known vulnerability cannot be used against it.

Answer the questions below

A vulnerability not patched by the vendor and unknown to most people is called a?

0-day

What is a commonly used term for a demonstration that proves the exploitability of a newly discovered vulnerability?

Proof of concept

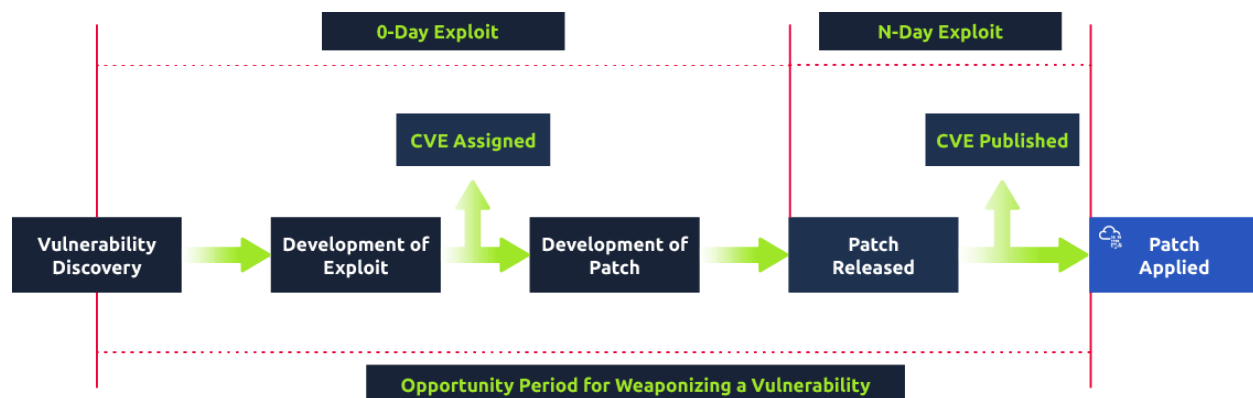
What does a product manufacturer typically release to prevent a known vulnerability from being exploited by adversaries?

patch

Task 4 - Opportunity for Weaponizing Vulnerabilities

Weaponizing vulnerabilities or creating exploits based on existing vulnerabilities is a process that requires a deep understanding of the target resource, whether it be software, hardware, or any other system that is being exploited. Creating an exploit involves steps that vary depending on the target system. It takes **time, expertise, and knowledge of the target** technology to be weaponized or exploitable.

A vulnerability may be weaponized by **locally developing an exploit or purchasing it from suppliers** in underground forums or specialized marketplaces. The flow chart shows an annotated picture highlighting the opportunity period for weaponizing a vulnerability.



The window of opportunity for resource exploitation varies and depends on several factors, including update availability, discovery time, and failure severity. Exploiting **0-day vulnerabilities can take a few days to several months or even years**. Since 0-day attacks are typically targeted at specific targets, finding them takes time and effort. In the above figure, the n-day refers to an exploit with a patch available. Here "n" refers to the number of days elapsed since the patch was released.

As mentioned above, the date when a vulnerability has first been discovered is typically unknown; however, the CVE database shows the dates of CVE-ID assignments and publications. CVEs are often released as soon as the vendors push out the patch. **Adversaries with access to the updated software can reverse-engineer the patch to find the vulnerability.** According to the [Exploit Database](#)(opens in new tab), most public exploits are created in the first week following the release of a patch. To offer their clients more time to upgrade, certain manufacturers might postpone the CVE announcement. When a CVE is formally released, the public can immediately access information about the vulnerability. Most security providers begin creating their vulnerability signatures and prevention strategies at this time to ensure mitigation from threat actors.

Answer the questions below

| Can it take days, months, or even years to develop a 0-day exploit?

yea

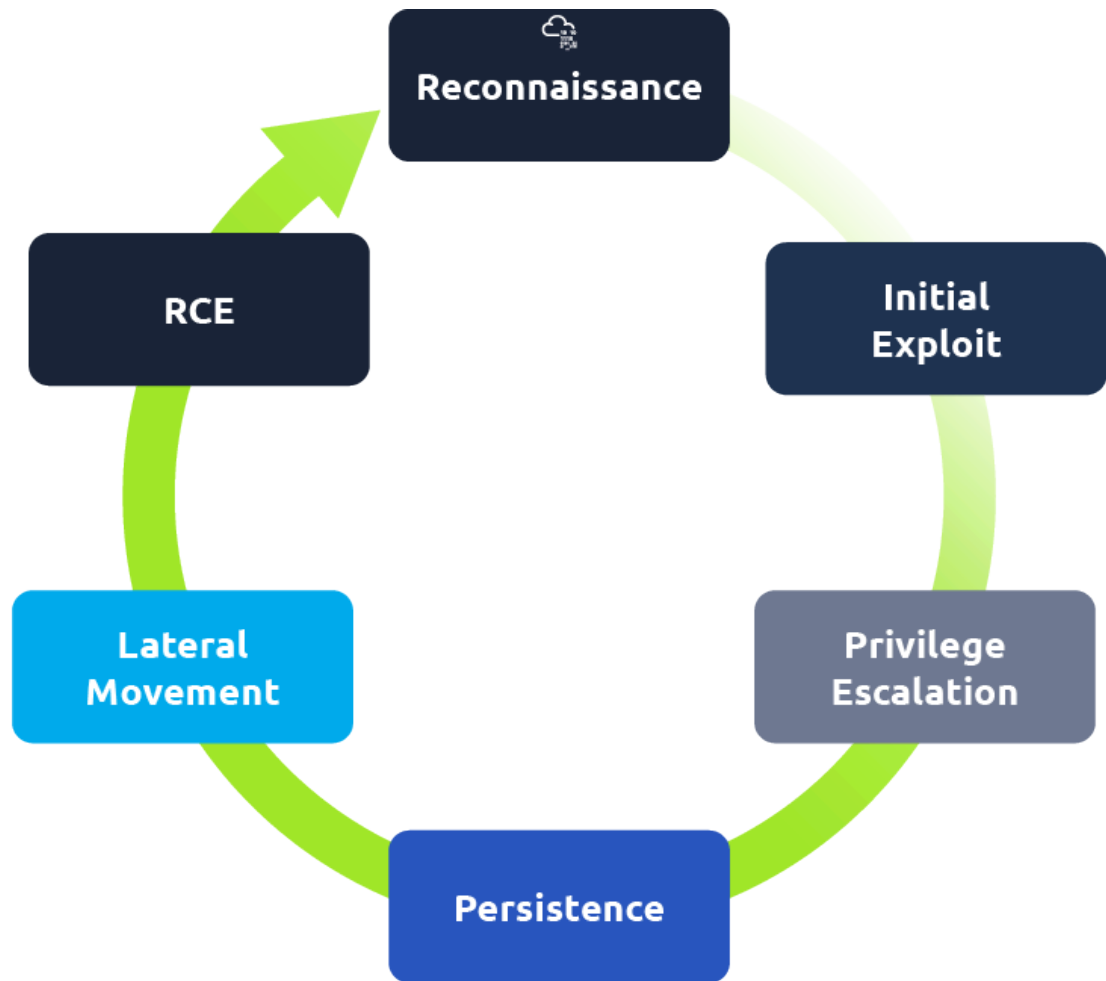
| An exploit developed once the vendor has released the patch is called?

n-day

Task 5 - Exploit Chaining

Chaining exploits in tandem, also known as "**exploit chaining**" or "**multi-stage exploitation**", is a technique hackers use to string together multiple exploits for vulnerabilities to gain complete control of a target system. The desired goal is to develop a complete **Remote Code Execution (RCE) chain**, allowing the attacker to execute arbitrary code on the target system with the highest privileges.

- **Reconnaissance:** The attacker will gather information about the target system and its vulnerabilities. This can be done through various methods, such as network scanning, port scanning, and vulnerability scanning.



- **Initial Exploit:** The attacker will use the information gathered during the reconnaissance phase to identify an initial vulnerability that can be exploited, which could be known and that has not been patched. The attacker will use an exploit that takes advantage of this vulnerability to gain access to the target system.
- **Privilege Escalation:** This will allow them to access sensitive information, such as login credentials and system files, and execute code with higher privileges.
- **Persistence:** The attacker will use other exploits to establish persistence on the target system, allowing them to maintain access even if the initial exploit is discovered and patched.
- **Lateral Movement:** The attacker will then use additional exploits to move laterally through the target system's network and compromise other systems.

This will allow them to gain access to additional sensitive information and resources.

- **RCE:** Once the attacker has established persistence and moved laterally through the network, they will use the final exploit in the chain to gain RCE. This may include using malware to gain control of the target system or a privilege escalation exploit to gain access to the target system's kernel.

Answer the questions below

| What is the technique called to string together multiple exploits?

Exploit chaining

| After initial access to the system, the process for gaining higher access within the system is called?

Privilege escalation

| The step in which the adversary tries to maintain long time access to the system is called?

persistence

Task 6 - Chaining Multiple Vulnerabilities - A Case Study

To demonstrate the process for "**exploit chaining in tandem to develop a complete RCE Remote Code Execution (RCE) chain**", let's examine a real-world situation. The exercise focuses more on how to chain vulnerabilities than **how to exploit a vulnerability**.

How to Chain Multiple Exploits: Using a case study, let's dig deeper into various phases of exploit chaining. The installation procedure and the fundamental commands are not covered as the goal of this study is to chain exploits for developing a complete RCE chain.



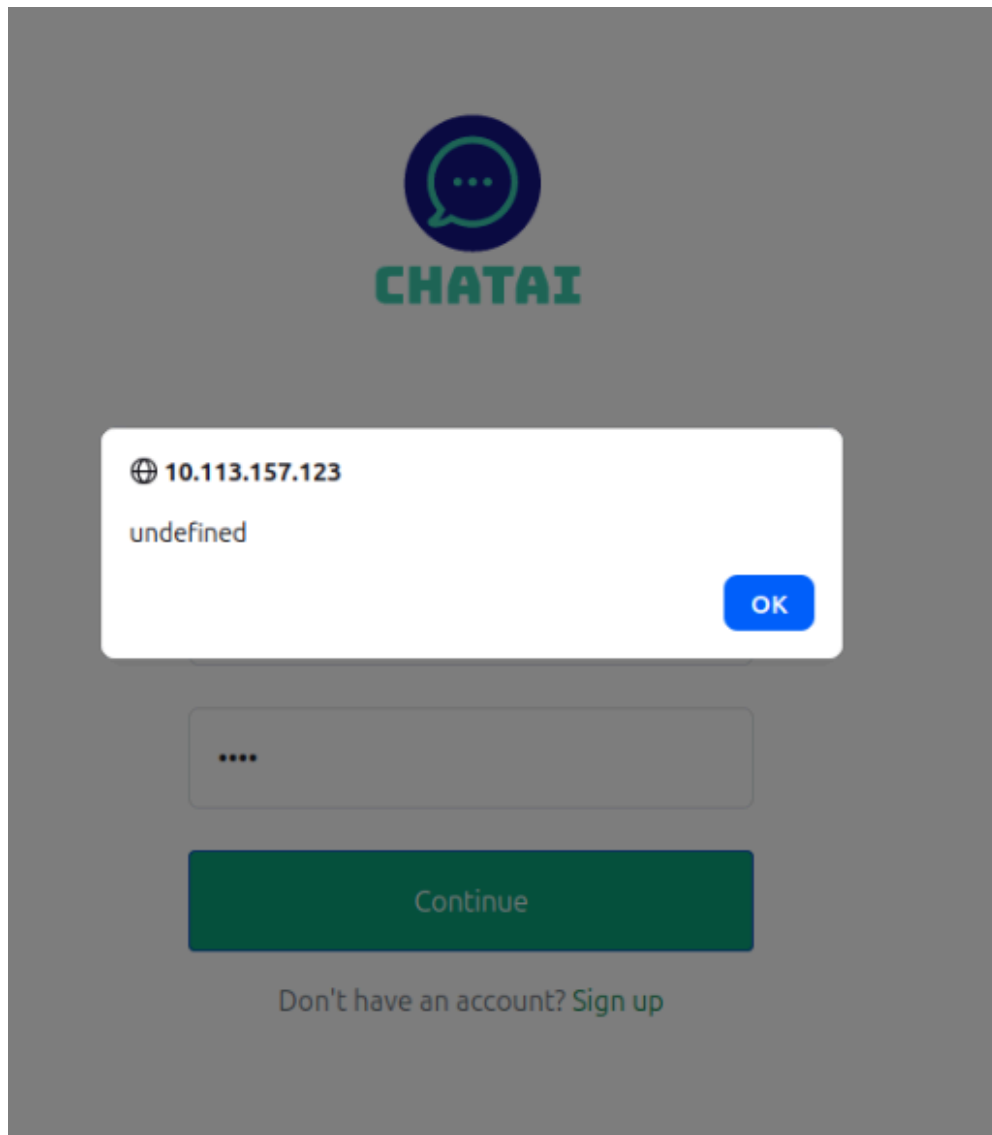
Welcome back

Don't have an account? [Sign up](#)

Answer the questions below

What is the response when we enter email test@chatai.com' as user email and password 123 in the login form?

undefined



Execute the command whoami, what is the output you receive?

nt authority\system

```

02/15/2023 03:06 PM <DIR> root
08/06/2022 10:36 AM 59 script.bat
02/15/2023 03:03 PM 164 shell.php
04/18/2023 04:34 PM 908 tmpbdxut.php
02/23/2023 01:26 PM 752 tmpubsob.php
02/24/2023 04:53 AM 0 tmpuketi.php
04/18/2023 04:34 PM 756 tmpukkpp.php
02/15/2023 12:47 PM 720 tmpukuxh.php
02/24/2023 04:55 AM 752 tmpulbks.php
08/06/2022 10:14 AM <DIR> webalizer
08/06/2022 10:14 AM <DIR> xampp
13 File(s) 39,067 bytes
8 Dir(s) 13,166,669,824 bytes free
---
os-shell> whoami
command standard output: 'nt authority\system'
os-shell>

```

Have you noticed the file flag.txt in the web root directory? What is the flag value?

THM{010101_PAWNED}

```

02/15/2023 03:06 PM <DIR> root
08/06/2022 10:36 AM 59 script.bat
02/15/2023 03:03 PM 164 shell.php
04/18/2023 04:34 PM 908 tmpbdxut.php
02/23/2023 01:26 PM 752 tmpubsob.php
02/24/2023 04:53 AM 0 tmpuketi.php
04/18/2023 04:34 PM 756 tmpukkpp.php
02/15/2023 12:47 PM 720 tmpukuxh.php
02/24/2023 04:55 AM 752 tmpulbks.php
08/06/2022 10:14 AM <DIR> webalizer
08/06/2022 10:14 AM <DIR> xampp
13 File(s) 39,067 bytes
8 Dir(s) 13,166,669,824 bytes free
---
os-shell> whoami
command standard output: 'nt authority\system'
os-shell> cd /root
command standard output: 'The system cannot find the path specified.'
os-shell> dir

```

```

---
os-shell> type flag.txt
command standard output: 'THM{010101_PAWNED}'
os-shell>

```

How many files are available in the C:\xampp\htdocs\img folder?

2

```
os-shell> dir img
command standard output:
---
Volume in drive C has no label.
Volume Serial Number is A8A4-C362

Directory of C:\xampp\htdocs\img

08/06/2022  10:14 AM    <DIR>          .
08/06/2022  10:14 AM    <DIR>          ..
08/27/2019  02:02 PM                751 module_table_bottom.png
08/27/2019  02:02 PM                337 module_table_top.png
                2 File(s)                1,088 bytes
                2 Dir(s)  13,234,724,864 bytes free
```

Task 7 - Automating Common Tasks

Several ways to automate these tasks include scripts, scheduling tools, and platforms that offer security orchestration, automation, and response (SOAR) capabilities.

- **Scripts:** One way to automate everyday tasks and security checks is to use scripts. Scripting languages like Python, PowerShell, and Bash can automate many tasks, including system administration, security checks, and data analysis. Scripts can automate repetitive tasks, such as scanning for vulnerabilities, monitoring network traffic, and collecting log data. Additionally, scripts can be used to perform complex tasks, such as automating incident response procedures and analyzing large data sets. For example, you can create a small script in PHP to go through log files and identify any malicious URLs or keywords:
- **Scheduling Tools:** Scheduling tools are another way to automate common tasks and security checks. Scheduling tools such as cron jobs and Windows Task Scheduler can be used to schedule scripts to run at specific times. This allows organizations to automate vulnerability scans, backups, and software updates. For example, a security engineer can use a vulnerability scanner tool

that automates identifying and analyzing vulnerabilities in the organization's network. The tool can scan the **network regularly, detecting vulnerabilities** that may have been introduced since the last scan. The tool can then generate reports on the vulnerabilities found, categorizing them by severity and providing recommended actions to remediate them.

- **SOAR Platforms:** A third way to automate everyday tasks and security checks is to use Security Orchestration, Automation and Response Platforms. These platforms provide a centralized management interface for automating and orchestrating security tasks. They can automate incident response, threat hunting, and incident management tasks. Additionally, they can be used to integrate with other security tools such as Firewalls, Intrusion Detection Systems, and **Security Information and Event Management (SIEM)** systems. [Shuffler.io](#)(opens in new tab) and [Splunk](#) are a few of the renowned **SOAR** Platforms that you can explore.

When automating tasks and security checks, it is important to consider the following best practices:

- Test your scripts and automation tools in a controlled environment before deploying them in production.
- Ensure that your scripts and automation tools are well-documented and easy to understand.
- Use logging and monitoring to keep track of the tasks that have been automated.
- Review your automation and security checks regularly to ensure they are still practical and relevant.
- Keep your scripts and automation tools updated and patched to address any security vulnerabilities.

In summary, automating common tasks and security checks can help organizations streamline operations and improve their overall security posture. When implementing automation, it is important to consider best practices such as testing, documentation, logging and monitoring, regular review, and security updates.

Answer the questions below

As a security engineer, is it important to ensure that automated scripts being executed are acquired from legitimate sources?

yea

Task 8 - Conclusion

Learned about the lifecycle of a vulnerability, how exploits are developed, and how to chain multiple vulnerabilities to get complete control of a system. Moreover, we have also briefly discussed how we could automate routine tasks to assist a security engineer.

In summary, creating exploits based on existing vulnerabilities is a complex process involving discovering vulnerabilities, research, exploit development, testing, and deployment. However, vulnerabilities and exploits must be dealt with using extreme care, and all testing should be carried out in an isolated environment to avoid infecting one's own system.